From fortnightly SSH deploys to audited, automated, zero-downtime releases

NovaPay Digital Bank · RBI-licensed · UPI-critical
Presented by: Mohammad Sinan Ali, DevOps Lead (simulation PIPELINE FORGE)

Deploy Fast. Stay Compliant. Never Go Down.

Ask of the Committee: approve the architecture and 90-day rollout (slide 20)
Everything cited is in the repository; what is not yet verified on a live cluster is marked as such.

1. The problem today

Current state of NovaPay

Pain point	Today	Risk / regulatory exposure
Deployment method	Manual SSH to production	Human error — Knight Capital lost $440 M in 45 min from a missed server
Deployment frequency	Once every 2 weeks	Large batches = bigger blast radius; slow response to fraud/security fixes
MTTR	4.5 hours	A UPI outage of 30 s at peak already affects millions of payments
Compliance	No automated scanning; 17 open RBI non-conformances	Audit findings; supervisory escalation
Database changes	Manual, 2 AM maintenance windows	Downtime + untested rollback
Observability	Customers detect incidents	Same failure pattern as YES Bank (2020)
Recent incidents	3 production incidents in Q4 2025 from untested code	Repeat events likely without gates

2. Objectives and measurable targets

What 'good' means

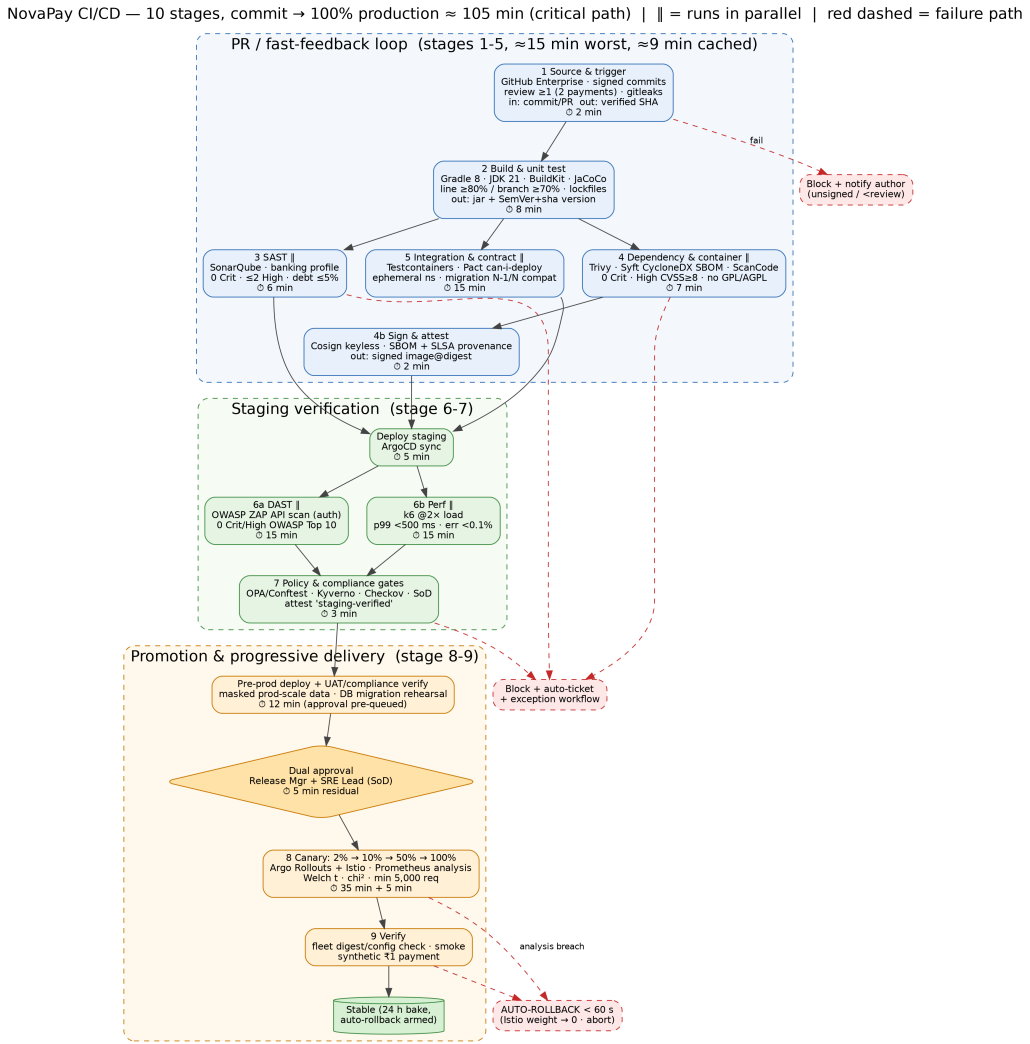
Metric	Today	Target	Design evidence
Commit → production	≥ 14 days	< 2 h	≈105 min critical path (itemised)
Deployments	1 / 2 weeks	multiple per day	trunk-based, parallel gates
MTTR / recovery	4.5 h	< 15 min	auto-rollback < 60 s (Category A)
Compliance evidence	0 % automated	100 % of releases	8 blocking gates + hash-chained audit log
Availability	not measured	99.999 % design target	multi-AZ, canary, auto-rollback, DR drills
Change failure rate	unknown	< 5 %	canary + analysis + fleet verification

Five-nines = ~5 min 15 s downtime a year. The pipeline reduces change-related risk; it cannot promise it alone.

3. Solution at a glance — 10-stage pipeline

docs/01-pipeline-architecture

- 8 canonical stages + **SBOM/sign** and **post-deploy verify** as auditable stages
- Parallel scans; failures stop the line (red paths)



- Every artefact: SemVer + digest, signed, SBOM + provenance
- GitOps (ArgoCD) deploys only what Git and policy allow
- Hotfix = **expedited, never bypassed**

4. Speed AND safety — timing budget

Step	Min	Cum.
Trigger + build + unit	10	10
SAST and deps+sign and integration (longest)	15	25
Deploy staging	5	30
DAST and perf	15	45
Policy gates	3	48
Pre-prod verify (approval pre-queued)	12 + 5	65
Canary 2 % → 10 % → 50 %	35	100
100 % + verification	5	≈105

- Commit → 100 %: ≈**105 min** (< 2 h)
- ≈58 % of jobs run in parallel
- Developer feedback ≈ 9–15 min
- ≈97 % automated (manual: dual approval, CAB if high-risk)
- **Two canary profiles**: standard (35 min) and high-risk (brief's 15/30/60 min + 24 h bake) — resolves a conflict inside the brief

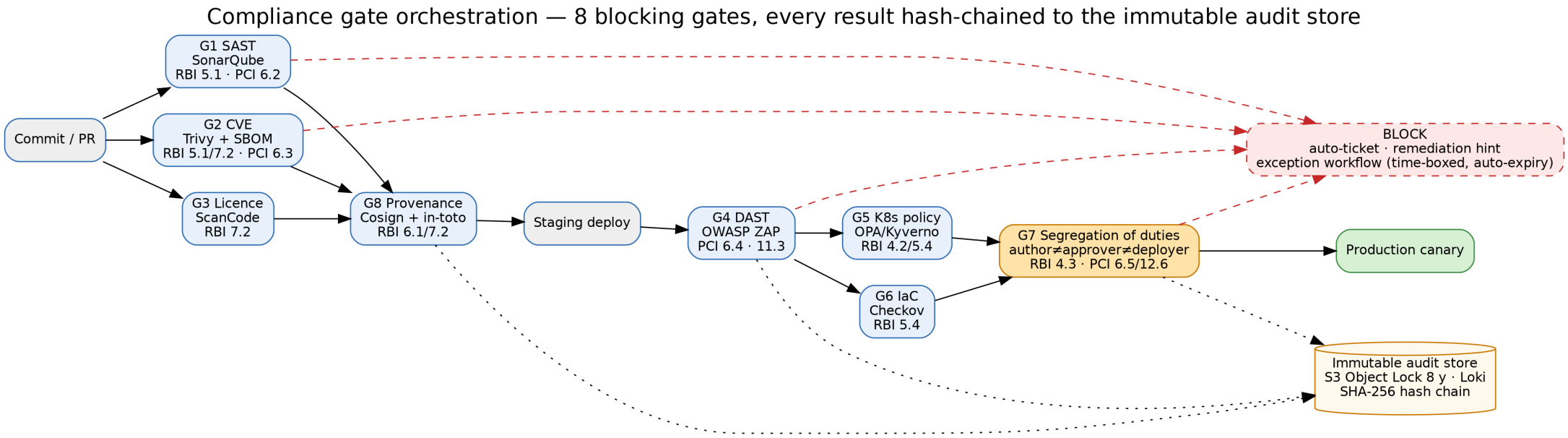
5. Compliance gates mapped to RBI and PCI-DSS v4.0

Gate	Tool	Blocking threshold	Control mapping
G1 SAST	SonarQube	0 Critical, ≤2 High, ≥80 % cov	RBI 5.1 · PCI 6.2
G2 CVE + SBOM	Trivy, Syft	0 Critical; High CVSS ≥8 (fix avail.)	RBI 5.1/7.2 · PCI 6.3
G3 Licence	ScanCode/FOSSA	no GPL/AGPL/SSPL	RBI 7.2
G4 DAST	OWASP ZAP	0 Critical/High (OWASP Top 10)	PCI 6.4, 11.3
G5 K8s policy	OPA / Kyverno	all policies pass; TLS 1.3	RBI 4.2/5.4
G6 IaC	Checkov	0 High; no privileged	RBI 5.4
G7 Segregation of duties	SoD check	author ≠ approver ≠ deployer; 2 approvers	RBI 4.3 · PCI 6.5
G8 Provenance	Cosign, in-toto	signed + attested digest only	RBI 6.1/7.2

Each gate: numeric thresholds · remediation hint · time-boxed exception with auto-expiry · JSON audit record. Penetration testing is PCI 11.4 (periodic), not in-pipeline. RBI section numbers follow the brief's mapping; paragraph references to be confirmed against the Master Direction before sign-off.

6. Gate orchestration and audit evidence

Immutable, hash-chained



- Every gate result → JSON record → S3 Object Lock (8 y) + Loki; SHA-256 chain verified hourly (alert if broken)
- Exceptions: named approver, ≤14–30 days, auto-expire and re-block
- Regulatory dashboard gives the auditor release-by-release proof without screenshots

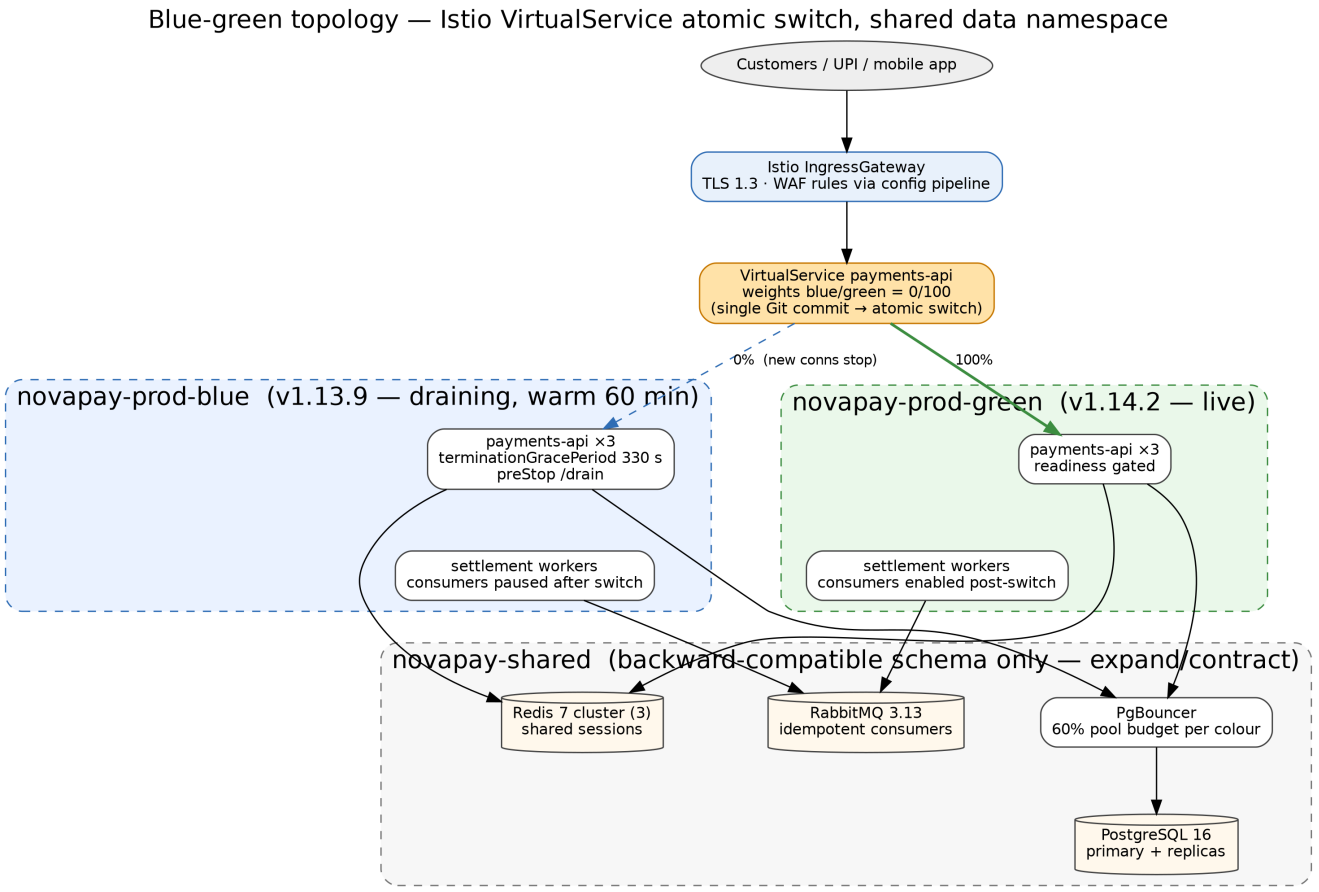
7. Supply chain and the hotfix bypass

- Images signed with **Cosign (keyless)**; SBOM (CycloneDX) and SLSA provenance attached; all GitHub Actions pinned to commit SHAs
- **Kyverno admission** rejects any image without a signature **and** a 'staging-verified' attestation — hotfixes included
- Branch rules: signed commits, mandatory review, **no admin bypass**
- Segregation of duties tested in policy code: self-approval, single approver, deployer = author all denied (5 tests)
- Config (WAF rules, flags, routing) travels the same pipeline as code — the Cloudflare 2019 lesson

Control sits at the cluster, not in a workflow file anyone can edit.

8. Zero-downtime deployment — blue-green

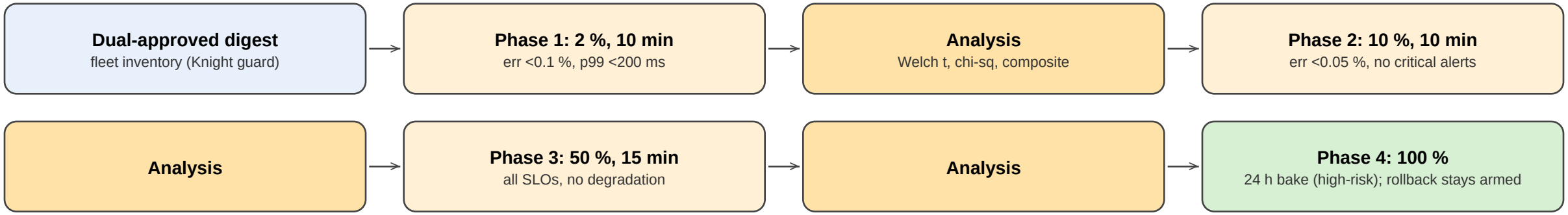
Istio VirtualService atomic switch



- Two namespaces behind one VirtualService; switch = single Git commit
- Shared PostgreSQL / Redis / RabbitMQ → **backward-compatible schema only**
- Connection draining: 60 s HTTP, 5 min payment settlement
- Idle colour kept warm 60 min = instant rollback
- Redis sessions shared: no logout on switch

9. Canary with statistical analysis

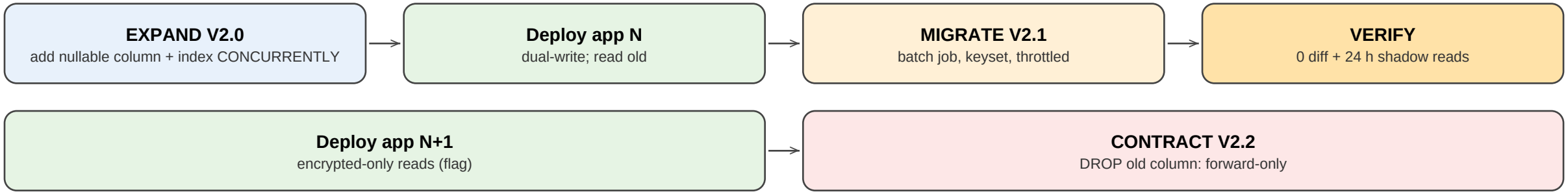
Argo Rollouts + Prometheus



- Every 60 s: **Welch t-test** (latency), **chi-squared** (error proportions), 95 % confidence, ≥5,000 requests per phase
- Composite score ≥90 promote · 70–89 extend (max 2×) · <70 rollback; thin data never promotes
- Tested: healthy canary promotes; latency+error regression rolls back (7 unit tests)
- Sandbox: IsolationForest anomaly detector flags multi-metric slow burns — advisory only

10. Zero-downtime database migration

Expand → Migrate → Contract (100 M rows)

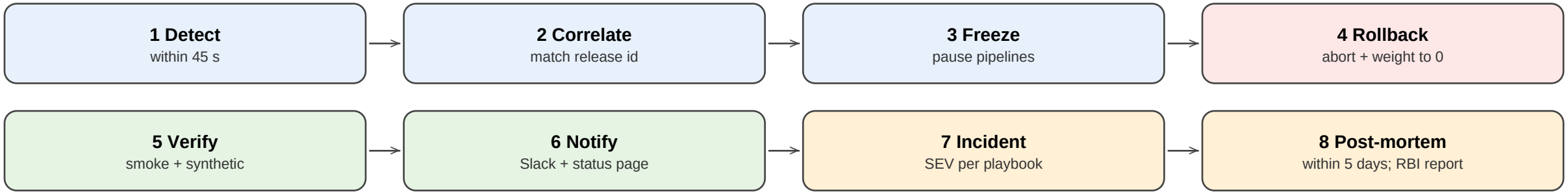


Phase	App N-1	App N	Rollback
Expand (V2.0)	works	works	DROP new column
Migrate (V2.1) batch job	works	works	stop — idempotent
Contract (V2.2)	must not run	works	forward-only: PITR + snapshot, CAB + DBA

- Tool: **pgroll** (gh-ost is MySQL-only) · keyset batches 5–10 k rows · abort on latency +20 % or replica lag >30 s
- Corrected the reference script: `CREATE INDEX CONCURRENTLY` cannot run in a transaction; backfill must commit per batch

11. Automated rollback — three tiers

docs/06-rollback-specification

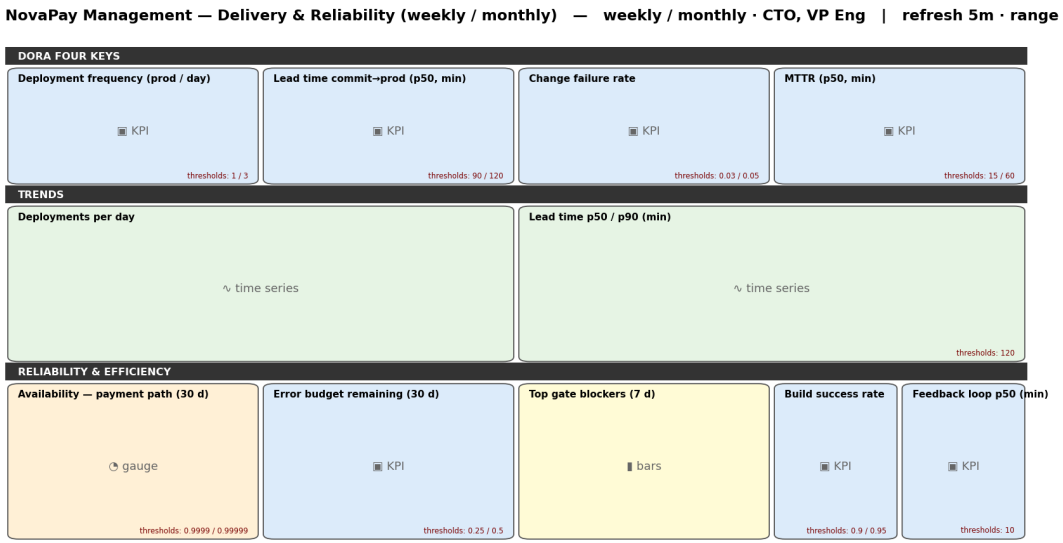


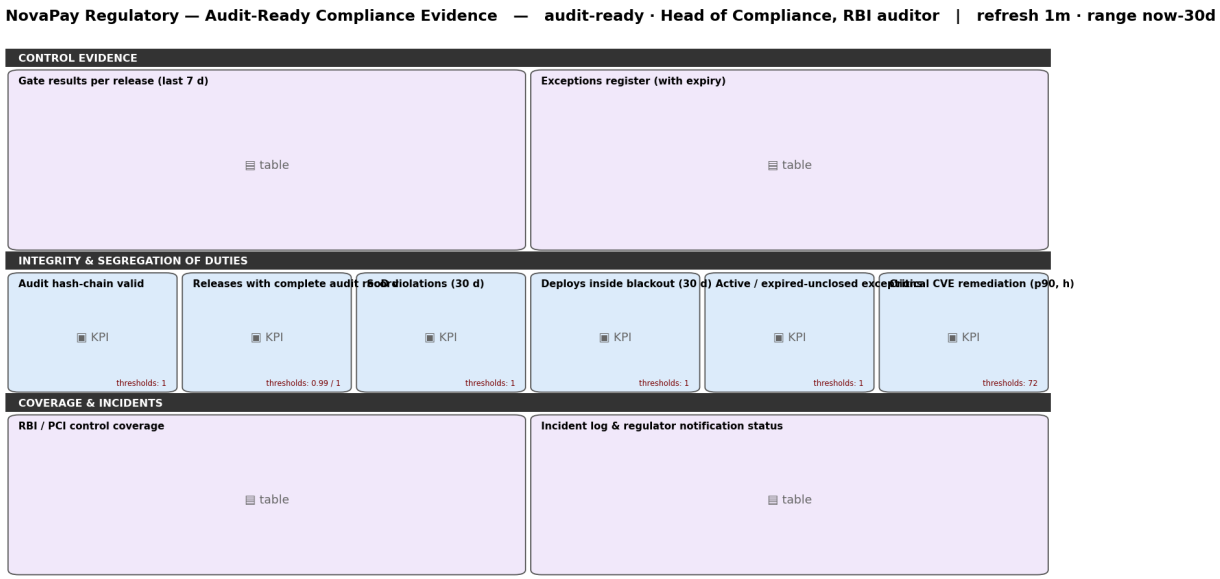
Category	Triggers (examples)	Action
A — < 60 s	5xx >5 % (30 s), probes ×3, OOM, CrashLoop, DB pool, gateway timeouts >20 %	automatic; no human
B — < 15 min	p99 >2× baseline, burn >10×, txn success –2 pp, CPU>90 %/mem>85 %	page on-call; auto at T+15
C — manual	slow burn, customer reports, retroactive CVE	human decision

Rollback path is independent of CI / registry / ArgoCD (break-glass script). 9 promtool unit tests pass, incl. the 12 % 5xx / pool / 35 % gateway scenario.

12. Observability, DORA and dashboards

Detect before customers do





- Three dashboards generated from code: Engineering (real-time) · Management (DORA, SLO) · Regulatory (audit-ready)
- UPI technical-decline >2 % detected ≤30 s (15 s scrape + 15 s eval) — unit-tested; incident >30 min opens regulatory task
- 18 pipeline metrics beyond DORA; alert routing by severity with escalation

13. Incident simulation — Friday 5:07 PM IST

Hotfix bypassed staging

T+	Event / decision
0	Alerts: 5xx 12 %, DB pool exhausted, gateway timeouts 35 %
20 s	Rollback-bot correlates to release, freezes pipeline, aborts canary (weight → 0)
30 s	On-call classifies **SEV-1**, takes Incident Commander role
2 min	Internal comms; CTO + CISO + VP Eng paged
3 min	Clean up leaked DB sessions; scale stable pods
5 min	Smoke + synthetic payments pass; status page updated
15 min	Baseline for 10 min → monitoring; resolution notice at T+30

- **MTTR** ≈ **5 min** vs 4.5 h today · customer impact ≈ 10 % of traffic for 2–3 min
- **Missing gates**: staging attestation enforcement, pool-saturation in canary analysis, blackout check inside deploy job, connection-budget policy

14. What four real failures changed in the design

Case	Failure	Control built	Evidence
Knight Capital 2012	7 of 8 servers updated; $440 M in 45 min	Fleet digest/config verification + kill switch	Fake-kubectl tests reproduce 7-of-8
YES Bank 2020	No observability, manual change, untested DR	30-s detection, auto status page, DR as scheduled test	promtool: TD % rule fires ≤30 s
Cloudflare 2019	Global WAF rule, no canary; 27 min, traffic –82 %	Config-as-code, canary, independent rollback, CPU breaker	config-change pipeline (D6)
SBI YONO 2023–24	Predictable salary-day load not tested; peak deploys	Blackout calendar, 5× load test ≤48 h before peaks, HPA	calendar + blackout-check script

15. Risk register — and what is not yet proven

Risk	Mitigation	Residual / status
Gates slow developers	Parallel jobs, p50 feedback <10 min, clear fix hints, friction metric	Measure first 30 days
False positives block releases	Triage SLA 24 h; time-boxed expiring waivers	Track FP rate per scanner
Single control plane (Argo / Istio) failure	Break-glass rollback independent of CI; DR drills	Test on cluster
Contract-phase data loss	Forward-only gate: CAB + DBA, PITR, ≥1 release zero reads	Rehearse on 100 M rows
Five-nines overpromised	State as design target; error-budget policy	Governance decision
Not yet executed live	Lab plan (kind + Istio + Argo Rollouts); policies/alerts/scripts already tested	**Open item**
ML anomaly model	Advisory only; synthetic data so far	Back-test on real history

16. Evidence the controls work

Executed, reproducible: validate.sh

Check	Result
Rego policy unit tests (images, privilege, limits, secrets, TLS 1.3, SoD)	13 / 13 pass
Rollback alert rules incl. Section B5 scenario (promtool)	5 tests pass, 9 rules
Observability rules: UPI ≤30 s, probes, 30-min timer, audit chain	4 tests pass, 11 rules
Canary statistics, fleet guard, ML sandbox (pytest)	15 passed
YAML lint, ShellCheck, Terraform fmt, JSON dashboards	pass
Helm lint, Terraform validate, live cluster	**not run** in build sandbox — to run locally

Everything above is in evidence/test-results/ and re-runs with one command.

17. Stakeholder concerns — how each is answered

Stakeholder	Likely challenge	Answer
CTO (Priya Mehta)	ROI and speed?	Fortnightly → multiple/day; 105-min budget; free/open-source toolchain
VP Eng (Arjun Singh)	Developer friction?	Fast loop <10 min p50, self-service, reusable workflows, friction metric
CISO (Kavitha Rao)	Threat model?	Signed + attested images, SBOM, admission control, SoD, no bypass
Head of Compliance (Deepak Nair)	Audit-ready evidence?	JSON audit per gate, hash chain, regulatory dashboard
RBI auditor	Proof of controls?	Control matrix + immutable records + tested policies
Dev team	Delays?	Parallel stages; exceptions handled via workflow, not tickets in limbo
SRE / Ops	On-call burden?	Auto-rollback <60 s, runbook tested at '3 AM' standard
TRC panel	What if it fails?	Three-tier rollback, forward-only steps gated, honest open items

18. 90-day rollout plan

Phased, reversible

Days	Milestone	Exit criterion
0–15	TRC approval of architecture; non-prod pipeline for 2 pilot services; dashboards live	Gates green on pilots; evidence pack
16–45	Staging + pre-prod GitOps, Kyverno in audit mode → enforce; SoD in GitHub Environments	0 unsigned images admitted; lab canary/rollback drills pass
46–75	Production canary for non-payment services; DB expand/contract rehearsal on 100 M rows	CFR <5 %, rollback <2 min measured
76–90	Payments services on pipeline; DR drill; RBI evidence walk-through; retire SSH deploys	17 non-conformances mapped to controls

SSH production access is removed only after two clean drills — never before.

19. Decision requested

- **Approve** the 10-stage architecture, 8 compliance gates and rollback tiers as the NovaPay release standard
- **Approve** the two canary profiles and the 2-hour commit-to-production SLO for standard-risk changes
- **Endorse** the time-boxed exception policy and the no-bypass rule for hotfixes
- **Fund** a lab cluster for the live validation listed as open on slide 16
- **Mandate** Compliance to confirm RBI/NPCI/CERT-In notification thresholds used in the playbook

Deploy Fast. Stay Compliant. Never Go Down.